

SentinelVault: An AI-Powered Adaptive Threat Intelligence Platform Using Digital-Twin Network Simulation for Sandbox-Evasive Malware Detection

A Full-Lifecycle Framework Integrating Pre-, Mid-, and Post-Exploitation Defence

Research Project Abstract | Domain: Cybersecurity, Malware Analysis, Applied AI | Scope: Pre-Exploitation → Mid-Exploitation → Post-Exploitation

Abstract

Modern evasive malware — particularly Advanced Persistent Threat (APT) tooling — routinely fingerprints the sandbox it is executed in and remains dormant when it detects a sterile, non-production analysis environment, allowing it to bypass conventional dynamic-analysis pipelines undetected. This work proposes **SentinelVault**, a full-lifecycle, AI-driven malware defence and threat-intelligence platform built around a single architectural insight: malware reveals its true behaviour only when it believes it is running inside a real organisation. Rather than detonating suspicious files in a generic sandbox, SentinelVault constructs a **convincing digital twin** of the target organisation's own network topology — complete with a simulated domain controller, file and email servers, employee endpoints, and live-looking user sessions — and detonates the file inside it. A **covert, hypervisor-level AI observer agent**, invisible to the executing process, monitors the run via VM introspection, classifies behaviour against the MITRE ATT&CK framework, and compiles a complete forensic brief once the run concludes. The system spans three integrated phases: (1) *pre-exploitation* interception and AI-based triage at the file-download layer; (2) *mid-exploitation* digital-twin detonation, covert observation, and type-specific adaptive containment; and (3) *post-exploitation* forensic evidence sealing, cryptographic sandbox disposal, twin reconstruction, and community threat-intelligence distribution via STIX/TAXII. Every containment or disclosure action is routed through a human-approval gate. The result is a self-improving detection loop that positions itself not merely as a defensive control but as a threat-intelligence platform capable of surfacing TTP-similarity signals, reconstructing exploit chains, predicting blast radius, and flagging zero-day candidates for analyst review — while responsibly deferring attribution and validated zero-day discovery to processes that require external corroboration.

Keywords: digital twin, sandbox evasion, malware detonation, hypervisor introspection, MITRE ATT&CK, threat intelligence, adaptive containment, STIX/TAXII, zero-day triage.

1. Problem Statement

Conventional sandboxes analyse files in generic, templated environments that sophisticated malware can fingerprint through environment checks — the absence of a real logged-in user, real files, domain membership, or plausible network activity causes the payload to stay dormant, producing a false-negative “benign” verdict. This is the core evasion technique exploited by APT-grade tooling and environment-aware ransomware. Existing tools typically optimise only one stage of the kill chain (gateway detection or post-incident forensics), leaving no single system that intercepts, deceives, observes, contains, and learns from an attack as one continuous pipeline.

2. Proposed System Architecture

SentinelVault is organised as three sequential phases forming a closed, self-improving loop:

Phase 1 – Pre-Exploitation: Every file download is intercepted at the proxy/DNS layer and passed through an AI pre-screening engine (hash lookup, YARA, ML classifier, phishing-URL check) that routes files to block-and-alert, pass-through, or deep sandbox analysis. Static analysis, CDR, a honeypot network observer, and a ransomware “time machine” (continuous snapshot + auto-rollback) run in parallel, feeding an attacker-intent engine and a 0–100 trust score that drives the final block/deliver decision.

Phase 2 – Mid-Exploitation: Files still classified as merely “suspicious” enter a full digital twin built from a one-time, continuously updated network-discovery phase — using the organisation's real hostnames, domain structure, and

folder conventions across a fake domain controller, file/email servers, web proxy, employee endpoints, database, and backup server. A dedicated detonation point lets the file execute while a covert AI agent observes via hypervisor-level VM introspection (undetectable to the malware), running a behaviour watcher, intent classifier, ATT&CK mapper, and risk scorer. Analysis is delivered as one **batch forensic report** only once the full run completes — a deliberate design choice, since verdicts issued against complete behaviour are more reliable than those issued mid-attack against partial evidence. Once classified, type-specific adaptive containment (ransomware, botnet, worm, RAT, trojan) is proposed via a one-click, human-approved action panel, alongside a predicted blast-radius map.

Phase 3 – Post-Exploitation: Volatile memory, network capture, file-system diffs, and the agent's forensic report are hash-chained, signed, and written to an immutable audit store *before* disposal. The sandbox VM is then hard-terminated, memory zeroed, disk cryptoshredded, and the VPC torn down — verifiable zero-persistence disposal. A fresh, patched, smarter digital twin is rebuilt for the next file. Sealed evidence feeds an intelligence-extraction engine producing a TTP-similarity report (confidence-scored against known groups, not hard attribution), a reviewer-confirmed zero-day candidate flag, an ATT&CK map, and an IOC package. Regular IOCs broadcast instantly via STIX/TAXII to platforms such as MISP; zero-day candidates follow a ~90-day responsible-disclosure embargo before public release.

3. Key Contributions / Novelty

- A high-fidelity, organisation-specific digital-twin sandbox designed specifically to defeat environment-aware sandbox evasion, rather than a generic detonation chamber.
- A stateless, hypervisor-level covert AI observer that cannot itself become a compromise target, and that reasons over a complete run rather than issuing unreliable live/streaming verdicts.
- Type-specific adaptive containment mapped to five malware families, converging into a blast-radius and business-impact prediction — not just a binary block/allow verdict.
- Cryptographically verifiable evidence handling and disposal (hash-chained audit trail, cryptoshredding) suitable for forensic and compliance use.
- An honestly scoped threat-intelligence output: TTP-similarity scoring instead of unverifiable actor attribution, and a reviewer-gated zero-day candidate flag instead of an automatic “discovery” claim.
- A human-approval gate on every containment, policy, firewall, or disclosure action, avoiding fully autonomous response to a false positive.

4. Expected Outcomes & Evaluation Direction

The framework targets three measurable outcomes: (i) increased detonation/activation rate of sandbox-aware malware samples compared to generic-sandbox baselines, evaluated against known evasive-malware corpora; (ii) reduced time-to-containment enabled by type-specific response playbooks and human-approved one-click actions; and (iii) community-level protection latency — the time from a single detonation to IOC availability across connected organisations via STIX/TAXII. The explicit scoping to the file-download attack surface (Figure 1.1 of the parent framework) is intended to keep v1 honestly bounded, positioning SentinelVault to sit alongside — not replace — existing email-gateway, endpoint, and firewall/IDS controls.

5. Conclusion

SentinelVault reframes malware defence as a continuous, self-improving loop rather than a single detection checkpoint. By combining a deception-grade digital twin, a covert hypervisor-level AI observer, and forensically sound disposal with community-scale intelligence sharing, the framework aims to detect evasive and APT-grade threats that generic sandboxes miss, while keeping every consequential action under human review. The full architecture, including all supporting diagrams (entry-point scoping, detection pipeline, digital twin, covert agent, adaptive containment, post-exploitation lifecycle, and the threat-intelligence platform), is documented in the accompanying full-lifecycle framework report.